

Enci/ VENTAS

Guia de Variables de Entorno

Configuracion Segura - Backend API, Frontend Web, App Vendedor y RAG

Versión 1.0
Julio 2026
Aplicación de Automatización de Fuerza de Ventas

Cliente	Enci / Enci Ventas
Representante receptor	Max
Equipo desarrollador	Grupo PLM - Universidad Tecnológica Metropolitana (UTEM)
Líder de equipo	Joshua Flores
Integrantes	Falon Berrios, Caroline Palacios y Eliseo Poblete
Repositorio oficial del MVP web	Chumajer14/Encipharm
Tipo de documento	Guía formal de variables, secretos, ambientes y validación de configuración

BACKEND Variables privadas	FRONTEND Variables VITE publicas	RAG DeepSeek solo backend	UAT Validacion readiness
--------------------------------------	--	-------------------------------------	------------------------------------

Criterio rector
Ninguna credencial real, llave privada, service account, token de proveedor, certificado o secreto operativo debe quedar versionado, compartido en capturas ni expuesto como variable VITE. Las variables publicas del frontend solo identifican servicios cliente y no deben conceder privilegios administrativos.

Tabla de Contenidos

1. Introducción
2. Principios de configuración segura
3. Distribución de archivos por componente
4. Variables de backend
5. Variables de frontend web
6. Variables de app vendedor y Flutter externo
7. Reglas por ambiente
8. Plantillas de referencia
9. Validación con readiness y Swagger
10. Gestión de secretos y rotación
11. Checklist de aceptación

1. Introducción

Este documento define la guía formal de variables de entorno para el proyecto Enci / Enci Ventas. Su objetivo es ordenar la configuración necesaria para ejecutar, validar y desplegar el MVP web avanzado sin exponer credenciales ni debilitar los controles de seguridad incorporados durante el desarrollo.

La configuración se divide por componente: backend FastAPI, frontend web React/Vite, app vendedor basada en Vite/PWA y aplicación móvil Flutter nativa Android desarrollada fuera del monorepo. Cada componente tiene una frontera clara entre variables públicas, variables privadas y secretos operativos.

Alcance del documento

La guía cubre nombres de variables, finalidad, ambiente esperado, riesgo de exposición y criterio de validación. No entrega credenciales reales ni reemplaza el almacenamiento seguro de secretos del cliente o del proveedor cloud.

1.1 Componentes cubiertos

Componente	Archivo o mecanismo	Naturaleza
Backend API FastAPI	Backend/.env o variables del runtime	Privado. Puede contener service account, DeepSeek y secretos backend.
Frontend web React/Vite	frontend/.env	Público al compilar. Solo admite VITE_* no sensibles.
App vendedor Vite/PWA	vendedor-app/.env	Público al compilar. Reutiliza Firebase web config y API base.
App Flutter nativa Android	google-services.json, dart-define o configuración equivalente	Entregable parcial externo al monorepo. No debe incluir secretos backend.
UAT / Producción	Variables del proveedor de hosting	Configuración administrada por entorno, con valores reales fuera del repositorio.

2. Principios de Configuración Segura

Las variables de entorno son parte del límite de seguridad del sistema. Un valor incorrecto puede impedir el arranque, abrir CORS indebidamente, exponer documentación técnica, permitir cambios temporales de rol o dejar inoperativo Firebase, RAG o Swagger autenticado.

- Los archivos .env reales quedan fuera de Git y deben manejarse como material sensible.
- Los archivos .env.example solo pueden contener nombres de variables y valores placeholder.
- Las variables VITE_* quedan embebidas en el bundle del navegador; por tanto, no deben contener llaves privadas, tokens de servidor ni API keys de proveedores con privilegios administrativos.
- Las credenciales Firebase Admin y la API Key de DeepSeek viven exclusivamente en backend o en el gestor seguro de secretos del ambiente.
- En UAT, staging y producción no debe habilitarse el cambio temporal de rol ni dejar CORS abierto a localhost.

2.1 Clasificación de variables

Clasificación	Ejemplos	Regla de manejo
Pública de cliente	VITE_FIREBASE_API_KEY, VITE_APP_NAME	Puede compilarse en frontend. No otorga permisos por sí sola.

Clasificación	Ejemplos	Regla de manejo
Privada de backend	FIREBASE_SERVICE_ACCOUNT_JSON, DEEPSEEK_API_KEY	Solo backend o secret manager. Nunca VITE_* ni repositorio.
Operativa	APP_ENV, APP_VERSION, CORS_ORIGINS	Controla comportamiento de ambiente y readiness.
Integración externa	GCS_BUCKET_DOCUMENTS, DEEPSEEK_BASE_URL	Debe revisarse antes de UAT y documentarse por ambiente.
Temporal de desarrollo	ENABLE_TEMPORARY_ROLE_SWITCHER	Solo desarrollo. Debe estar deshabilitada en UAT y producción.

3. Distribución de Archivos por Componente

La estructura esperada del monorepo separa backend, frontend web y app vendedor. Esta separación permite que cada runtime cargue únicamente las variables necesarias para su operación.

Ruta	Uso	Debe versionarse
Backend/.env	Variables reales del backend local: Firebase Admin, CORS, RAG, readiness.	No
Backend/.env.example	Plantilla sin secretos para documentar variables esperadas.	Sí
frontend/.env	Variables del frontend web para desarrollo local.	No
frontend/.env.example	Plantilla pública de frontend.	Sí
vendedor-app/.env	Variables de la app vendedor Vite/PWA.	No
vendedor-app/.env.example	Plantilla pública de app vendedor.	Sí
google-services.json	Configuración Firebase Android para Flutter.	Solo si no contiene secretos privados y el cliente lo autoriza
serviceAccountKey.json	Credencial Firebase Admin SDK local.	No

Regla de repositorio

Antes de cualquier commit se debe revisar que no existan .env reales, service accounts, archivos de credenciales, llaves DeepSeek, tokens de Vercel, certificados ni JSON privados de administración Firebase.

4. Variables de Backend

El backend FastAPI consume variables desde Backend/.env en local o desde el runtime del proveedor de despliegue. Estas variables determinan el nombre de la API, ambiente, versión, CORS, autenticación Firebase Admin, consola Swagger, RAG y almacenamiento de documentos.

4.1 Catálogo general

Variable	Requerida	Ambiente	Descripción
APP_NAME	Sí	Todos	Nombre visible de la API y documentación técnica.
APP_ENV	Sí	Todos	Ambiente activo: development, uat, staging o production.
APP_VERSION	Sí	Todos	Versión reportada por readiness y usada como referencia de salida.
ENABLE_TEMPORARY_ROLE_SWITCHER	Sí	Dev	Habilita cambio temporal de rol solo para desarrollo. Debe ser false fuera de development.

Variable	Requerida	Ambiente	Descripción
CORS_ORIGINS	Sí	Todos	Lista JSON o valores separados por coma con orígenes permitidos.
CORS_ORIGIN_REGEX	Opcional	Preview	Regex acotada para previews Vercel. No debe aceptar todo.
FIREBASE_PROJECT_ID	Sí	Todos	ID del proyecto Firebase usado por Auth, Firestore y Admin SDK.
GOOGLE_APPLICATION_CREDENTIALS	Alternativa	Local/VM	Ruta a service account local. No se versiona.
FIREBASE_SERVICE_ACCOUNT_JSON	Alternativa	Serverless	JSON de service account como secreto del runtime.
FIREBASE_WEB_API_KEY	Opcional	No prod	Configura login Google en consola /docs.
FIREBASE_WEB_AUTH_DOMAIN	Opcional	No prod	Auth domain para consola Swagger autenticada.
FIREBASE_WEB_APP_ID	Opcional	No prod	App ID Firebase web para /docs.
DEEPSEEK_API_KEY	Sí para RAG	Backend	Llave del proveedor DeepSeek. Nunca frontend.
DEEPSEEK_BASE_URL	Sí para RAG	Backend	Base URL del proveedor RAG.
DEEPSEEK_MODEL	Sí para RAG	Backend	Modelo activo para generación de respuestas.
MAX_TOKENS_RESPONSE	Opcional	Backend	Límite de salida por respuesta RAG.
MAX_CONTEXT_CHUNKS	Opcional	Backend	Cantidad máxima de fragmentos usados como contexto.
SIMILARITY_THRESHOLD	Opcional	Backend	Umbral de similitud semántica para recuperación.
CHROMA_PERSIST_DIR	Opcional	Backend	Directorio local del índice vectorial Chroma.
GCS_BUCKET_DOCUMENTS	Opcional	Prod	Bucket GCS para documentos RAG en producción.
LOCAL_DOCUMENT_STORAGE_DIR	Opcional	Local	Directorio local para documentos cuando no hay bucket GCS.
RAG_CHAT_RATE_LIMIT_PER_MINUTE	Sí	Backend	Límite de consultas RAG por usuario.
RAG_MAX_UPLOAD_BYTES	Sí	Backend	Tamaño máximo de carga documental RAG.

4.2 Plantilla Backend/.env local

```
APP_NAME=Enci Ventas API
APP_ENV=development
APP_VERSION=1.0.0
ENABLE_TEMPORARY_ROLE_SWITCHER=false

CORS_ORIGINS=["http://localhost:5173","http://127.0.0.1:5173","http://127.0.0.1:5174"]
CORS_ORIGIN_REGEX=

FIREBASE_PROJECT_ID=your-project-id
GOOGLE_APPLICATION_CREDENTIALS=serviceAccountKey.json
FIREBASE_SERVICE_ACCOUNT_JSON=

FIREBASE_WEB_API_KEY=your-firebase-web-api-key
FIREBASE_WEB_AUTH_DOMAIN=your-auth-domain
FIREBASE_WEB_STORAGE_BUCKET=your-storage-bucket
FIREBASE_WEB_MESSAGING_SENDER_ID=your-sender-id
FIREBASE_WEB_APP_ID=your-web-app-id
FIREBASE_WEB_MEASUREMENT_ID=your-measurement-id

DEEPSEEK_API_KEY=your-deepseek-api-key
DEEPSEEK_BASE_URL=https://api.deepseek.com
DEEPSEEK_MODEL=deepseek-chat
MAX_TOKENS_RESPONSE=1024
MAX_CONTEXT_CHUNKS=5
SIMILARITY_THRESHOLD=0.30
CHROMA_PERSIST_DIR=./chroma_db
LOCAL_DOCUMENT_STORAGE_DIR=./document_storage
GCS_BUCKET_DOCUMENTS=
RAG_CHAT_RATE_LIMIT_PER_MINUTE=30
RAG_MAX_UPLOAD_BYTES=20971520
```

4.3 Condiciones de backend por ambiente

Ambiente	APP_ENV	CORS	Swagger / OpenAPI	RAG
Local	development	Puede incluir localhost y 127.0.0.1.	Permitido para pruebas.	Puede operar con almacenamiento local.
UAT	uat	Solo dominios UAT autorizados.	Permitido solo si se requiere validación controlada.	Debe tener DeepSeek y documentos definidos.
Staging	staging	Solo dominios staging/preview acotados.	Restringido según criterio técnico.	Debe usar secretos del runtime.
Producción	production	Sin wildcard ni localhost.	No expuesto.	Debe tener llaves y bucket gestionados por entorno.

5. Variables de Frontend Web

El frontend web está construido con React + Vite. Toda variable con prefijo VITE_* queda disponible en el bundle final de navegador. Por diseño, estas variables no deben contener secretos ni llaves de administración.

5.1 Catálogo frontend

Variable	Requerida	Uso	Sensibilidad
VITE_APP_NAME	Sí	Nombre visible de la aplicación.	Pública
VITE_API_BASE_URL	Sí	URL base de la API FastAPI consumida por el frontend.	Pública
VITE_ENABLE_TEMP_ROLE_SWITCHER	Opcional	Control visual para rol temporal en desarrollo.	Pública; false fuera de dev
VITE_FIREBASE_API_KEY	Sí	Firebase web config para Auth desde navegador.	Pública

Variable	Requerida	Uso	Sensibilidad
VITE_FIREBASE_AUTH_DOMAIN	Sí	Dominio de autenticación Firebase.	Pública
VITE_FIREBASE_PROJECT_ID	Sí	ID del proyecto Firebase web.	Pública
VITE_FIREBASE_STORAGE_BUCKET	Sí	Bucket asociado a Firebase web.	Pública
VITE_FIREBASE_MESSAGING_SENDER_ID	Sí	Sender ID del proyecto Firebase.	Pública
VITE_FIREBASE_APP_ID	Sí	App ID de Firebase web.	Pública
VITE_FIREBASE_MEASUREMENT_ID	Opcional	Medición Firebase/Analytics si aplica.	Pública
VITE_FIREBASE_FREE_TIER_MODE	Opcional	Reduce refetches y consumo de cuota Firebase.	Pública

5.2 Plantilla frontend/.env

```
VITE_APP_NAME=Enci Ventas
VITE_API_BASE_URL=http://127.0.0.1:8000
VITE_ENABLE_TEMP_ROLE_SWITCHER=false

VITE_FIREBASE_API_KEY=your-firebase-api-key
VITE_FIREBASE_AUTH_DOMAIN=your-auth-domain
VITE_FIREBASE_PROJECT_ID=your-project-id
VITE_FIREBASE_STORAGE_BUCKET=your-storage-bucket
VITE_FIREBASE_MESSAGING_SENDER_ID=your-sender-id
VITE_FIREBASE_APP_ID=your-firebase-app-id
VITE_FIREBASE_MEASUREMENT_ID=your-measurement-id
VITE_FIREBASE_FREE_TIER_MODE=true
```

Restricción VITE

No se debe colocar DEEPSEEK_API_KEY, FIREBASE_SERVICE_ACCOUNT_JSON, GOOGLE_APPLICATION_CREDENTIALS, tokens de Vercel, claves privadas ni credenciales de admin en variables VITE_*. Todo valor VITE puede ser inspeccionado desde el navegador.

6. Variables de App Vendedor y Flutter Externo

El proyecto contempla una app vendedor Vite/PWA dentro del monorepo y una app Flutter nativa Android parcialmente realizada fuera del repositorio. Ambas deben respetar la misma regla: consumir API mediante autenticación Firebase y no incorporar secretos backend.

6.1 App vendedor Vite/PWA

La app vendedor utiliza variables públicas equivalentes al frontend web, con VITE_API_BASE_URL apuntando a la API local, al proxy de Vercel o a la URL HTTPS del backend según ambiente.

```
VITE_API_BASE_URL=/api
VITE_FIREBASE_API_KEY=your-firebase-api-key
VITE_FIREBASE_AUTH_DOMAIN=your-auth-domain
VITE_FIREBASE_PROJECT_ID=your-project-id
VITE_FIREBASE_STORAGE_BUCKET=your-storage-bucket
VITE_FIREBASE_MESSAGING_SENDER_ID=your-sender-id
VITE_FIREBASE_APP_ID=your-firebase-app-id
```

Ambiente	VITE_API_BASE_URL esperado	Observación
Local	http://127.0.0.1:8000	Consume backend local iniciado por uvicorn.
Preview / Vercel	/api	Usa proxy del proyecto vendedor-app hacia backend publicado.

Ambiente	VITE_API_BASE_URL esperado	Observación
Producción	/api o URL HTTPS	Debe apuntar al backend productivo autorizado por CORS.

6.2 Aplicación Flutter nativa Android

La app Flutter se entiende como entregable parcial externo al monorepo, desarrollado conforme al alcance acordado con Max. Su configuración debe mantenerse separada del backend y limitarse a datos necesarios para Firebase Auth, API base y funcionamiento cliente Android.

Elemento	Uso esperado	Criterio de seguridad
google-services.json	Config Firebase Android para login Google/Firebase.	No debe contener service accounts ni credenciales Admin SDK.
API_BASE_URL	URL HTTPS o local de backend FastAPI.	Debe coincidir con CORS y ambiente validado.
FIREBASE_PROJECT_ID	Identificación del proyecto Firebase.	Puede ser público; no concede permisos por sí solo.
DEEPSEEK_API_KEY	No aplica en Flutter.	Prohibido en app móvil.
FIREBASE_SERVICE_ACCOUNT_JSON	No aplica en Flutter.	Prohibido en app móvil.

Cierre de alcance Flutter

La app Flutter no debe evaluarse por presencia dentro del repositorio GitHub del MVP web. Se documenta como componente externo parcial. Toda integración adicional, publicación en tiendas, firma productiva, MDM o cobertura completa de endpoints corresponde a nuevo acuerdo o Fase 2.

7. Reglas por Ambiente

Cada ambiente debe tener valores propios. Copiar configuraciones locales a UAT o producción sin revisión puede dejar el sistema en estado not_ready o exponer endpoints no destinados a salida productiva.

Regla	Desarrollo local	UAT	Producción
APP_ENV	development	uat	production
ENABLE_TEMPORARY_ROLE_SWITCHER	Puede usarse solo si se requiere prueba controlada	false	false
CORS_ORIGINS	localhost y 127.0.0.1 permitidos	Solo dominio UAT	Solo dominio productivo
/docs y /openapi.json	Habilitados para pruebas	Controlado según necesidad	No expuestos
Credenciales Firebase Admin	Archivo local excluido de Git	Secret manager o variable segura	Secret manager o variable segura
DeepSeek	Puede usarse para prueba	Solo si RAG se valida	Solo si cliente asume operación y costo
Almacenamiento RAG	Local document_storage	Bucket o storage definido	Bucket GCS o equivalente

7.1 CORS obligatorio

CORS debe permitir únicamente los orígenes que realmente consumirán la API. En producción no se acepta wildcard, regex global ni dominios locales. Los dominios de preview deben controlarse mediante una expresión regular acotada y revisada.

```
# Local permitido
CORS_ORIGINS=http://localhost:5173,http://127.0.0.1:5173,http://127.0.0.1:5174

# Produccion esperado
CORS_ORIGINS=https://enciopharm.vercel.app,https://enciapp.vercel.app
CORS_ORIGIN_REGEX=https://(enciopharm|enciapp)-[a-z0-9-]+chumajer14s-projects\.vercel\.app$
```

8. Plantillas de Referencia

Las siguientes plantillas son referencias para levantar ambiente. Los valores placeholder deben reemplazarse por datos reales del ambiente correspondiente antes de ejecutar la aplicación.

8.1 Backend mínimo sin RAG

```
APP_NAME=Enci Ventas API
APP_ENV=development
APP_VERSION=1.0.0
ENABLE_TEMPORARY_ROLE_SWITCHER=false
CORS_ORIGINS=http://localhost:5173,http://127.0.0.1:5173
FIREBASE_PROJECT_ID=your-project-id
GOOGLE_APPLICATION_CREDENTIALS=serviceAccountKey.json
```

8.2 Backend con RAG parcial habilitado

```
DEEPSEEK_API_KEY=your-deepseek-api-key
DEEPSEEK_BASE_URL=https://api.deepseek.com
DEEPSEEK_MODEL=deepseek-chat
MAX_TOKENS_RESPONSE=1024
MAX_CONTEXT_CHUNKS=5
SIMILARITY_THRESHOLD=0.30
CHROMA_PERSIST_DIR=./chroma_db
LOCAL_DOCUMENT_STORAGE_DIR=./document_storage
RAG_CHAT_RATE_LIMIT_PER_MINUTE=30
RAG_MAX_UPLOAD_BYTES=20971520
```

8.3 Frontend web mínimo

```
VITE_APP_NAME=Enci Ventas
VITE_API_BASE_URL=http://127.0.0.1:8000
VITE_FIREBASE_API_KEY=your-firebase-api-key
VITE_FIREBASE_AUTH_DOMAIN=your-auth-domain
VITE_FIREBASE_PROJECT_ID=your-project-id
VITE_FIREBASE_STORAGE_BUCKET=your-storage-bucket
VITE_FIREBASE_MESSAGING_SENDER_ID=your-sender-id
VITE_FIREBASE_APP_ID=your-firebase-app-id
```

9. Validación con Readiness y Swagger

La validación de variables críticas debe realizarse antes de UAT o go-live. El endpoint GET /readiness entrega un reporte no sensible del estado de configuración mínima y no debe exponer secretos.

Validación	Resultado esperado	Criterio de cierre
FIREBASE_PROJECT_ID	No usa placeholder	Debe apuntar al proyecto correcto.
Credencial Admin SDK	Existe archivo local o JSON seguro	Backend puede validar tokens Firebase.
CORS_ORIGINS	Contiene orígenes necesarios	No debe bloquear frontend autorizado.
CORS en UAT/Prod	Sin localhost ni wildcard	Condición necesaria para salida controlada.
ENABLE_TEMPORARY_ROLE_SWITCHER	false fuera de desarrollo	No permite escalamiento temporal.

Validación	Resultado esperado	Criterio de cierre
DeepSeek	API key presente si se valida RAG	Chat RAG opera en estado parcial acordado.

9.1 Comandos de verificación

```
# Backend local
cd Backend
uv run uvicorn app.main:app --host 127.0.0.1 --port 8000 --reload

# Salud y readiness
curl http://127.0.0.1:8000/health
curl http://127.0.0.1:8000/readiness

# Frontend web
cd frontend
npm run dev -- --host 127.0.0.1 --port 5173
```

Swagger controlado

La consola /docs puede usarse en desarrollo y validación controlada para login con Google y pruebas de endpoints protegidos. En producción debe mantenerse no expuesta según el criterio de hardening del MVP.

10. Gestión de Secretos y Rotación

La administración de secretos debe contemplar custodia, rotación y respuesta ante exposición accidental. El equipo no debe conservar credenciales reales una vez completada la entrega, salvo que exista acuerdo explícito de soporte posterior.

Secreto	Custodio esperado	Rotación recomendada	Acción ante exposición
Firebase service account	Cliente / administrador cloud	Al cierre, cambio de responsable o sospecha	Revocar llave, crear nueva, actualizar backend.
DEEPSEEK_API_KEY	Cliente / responsable RAG	Al cierre o cambio de proveedor	Revocar key y reemplazar en runtime.
Tokens de deploy	Responsable de infraestructura	Al cierre de entrega o cambio de equipo	Revocar token y auditar despliegues.
google-services.json	Cliente / responsable Android	Si cambia proyecto Firebase	Regenerar config y rebuild de APK.
Variables VITE	Responsable frontend	Cuando cambie Firebase o API	Rebuild y redeploy del frontend.

10.1 Procedimiento ante filtración

- 1 Identificar el secreto expuesto, ruta, fecha y personas con acceso.
- 2 Revocar o rotar la credencial en el proveedor correspondiente.
- 3 Actualizar variable en backend, hosting o aplicación móvil según corresponda.
- 4 Eliminar el secreto de commits, archivos, capturas o canales compartidos.
- 5 Ejecutar prueba de arranque, health, readiness y flujo de autenticación.
- 6 Registrar incidente, mitigación aplicada y responsable de cierre.

11. Checklist de Aceptación

Código	Condición	Estado esperado
ENV-01	Backend/.env existe localmente y no está versionado.	Cumplido

Código	Condición	Estado esperado
ENV-02	FIREBASE_PROJECT_ID apunta al proyecto correcto.	Cumplido antes de UAT
ENV-03	Solo una modalidad Admin SDK activa: archivo local o JSON seguro.	Cumplido
ENV-04	CORS no incluye wildcard ni localhost en UAT/producción.	Cumplido
ENV-05	ENABLE_TEMPORARY_ROLE_SWITCHER=false fuera de development.	Cumplido
ENV-06	Frontend solo contiene variables VITE_* públicas.	Cumplido
ENV-07	DEEPSEEK_API_KEY solo existe en backend o secret manager.	Cumplido
ENV-08	RAG_MAX_UPLOAD_BYTES y rate limit están configurados.	Cumplido
ENV-09	GET /readiness no expone secretos y reporta estado del ambiente.	Cumplido
ENV-10	App Flutter externa no contiene service account ni DeepSeek key.	Cumplido para cierre parcial

Cierre documental

El cumplimiento de esta guía permite validar que la configuración del sistema está separada por ambiente, que los secretos no se exponen al cliente navegador y que los componentes parciales RAG y Flutter se mantienen dentro del alcance acordado para el Hito 5.